Control ID	Annex A Theme	Control Name	Applicable (Yes/No)	Linked Asset ID	Justification for Inclusion or Exclusion	Implementation Status	Control Implementation & Audit Evidence
Annex A.5.1	Organizational	Policies for information security	Yes	All Assets (Governance)	Mandatory under Clause 5.2 to establish executive security governance and direction across NexusCloud SaaS.	Implemented	Approved Information Security Policy (v2.4) published on internal Confluence Wiki and reviewed annually.
Annex A.5.7	Organizational	Threat intelligence	Yes	AST-01 / AST-07	Required to proactively track CVEs and emerging threats targeting cloud Kubernetes clusters and open-source packages.	Implemented	Automated threat feeds via GitHub Dependabot, AWS Security Hub, and CISA advisories.
Annex A.5.9	Organizational	Inventory of information and other associated assets	Yes	All Assets (AST-01 to AST-15)	Required to maintain visibility and ownership of all production cloud resources, databases, and endpoints.	Implemented	Automated AWS Config asset inventory, Terraform state tracking, and CMDB asset register.
Annex A.5.15	Organizational	Access control	Yes	AST-01 / AST-04 / AST-09	Essential to enforce Principle of Least Privilege (PoLP) and role-based access across cloud and internal systems.	Implemented	Centralized Access Control Policy enforced via Okta SSO and AWS IAM Role-Based Access Control (RBAC).
Annex A.5.17	Organizational	Authentication information	Yes	AST-03 / AST-04 / AST-05	Mitigates credential stuffing and phishing attacks against corporate identity providers and developer accounts.	Implemented	Mandatory FIDO2/WebAuthn hardware MFA (YubiKeys) and strict passwordless SSO authentication policies.
Annex A.5.18	Organizational	Access rights	Yes	AST-04 / AST-09	Prevents orphaned accounts and privilege creep during employee onboarding, role changes, and terminations.	Implemented	Automated Python access reconciliation script comparing active server/IAM accounts against HR records plus quarterly reviews.
Annex A.5.19	Organizational	Information security in supplier relationships	Yes	AST-11	Mitigates third-party supply chain risks from external SaaS vendors and API integrations.	Implemented	Third-Party Vendor Risk Assessment Matrix and annual review of vendor SOC 2 Type II reports.
Annex A.5.29	Organizational	Information security during disruption	Yes	AST-15	Ensures security controls remain intact during cloud region outages or disaster failover events.	Implemented	Documented Business Continuity Plan (BCP) and multi-region failover security runbooks.
Annex A.5.30	Organizational	ICT readiness for business continuity	Yes	AST-08 / AST-15	Ensures recovery time objectives (RTO) and recovery point objectives (RPO) are met during ransomware or outage events.	Implemented	Annual full-scale Disaster Recovery restoration drills and cross-region AWS backup replication.
Annex A.6.1	People	Screening	Yes	AST-09 (All Personnel)	Verifies identity and background of all engineering, support, and administrative hires prior to granting access.	Implemented	HR pre-employment background verification records and onboarding sign-off tracker.
Annex A.6.2	People	Terms and conditions of employment	Yes	AST-03 / AST-09	Contractually binds employees and contractors to confidentiality, IP protection, and acceptable use rules.	Implemented	Signed Non-Disclosure Agreements (NDAs) and Acceptable Use Policy acknowledgements in HRIS.
Annex A.6.3	People	Information security awareness, education and training	Yes	AST-05 / AST-06 / AST-13	Reduces human-factor risk from phishing, social engineering, and malware execution on employee laptops.	Implemented	Mandatory onboarding security training, quarterly refresher modules, and monthly phishing simulation reports.
Annex A.7.4	Physical	Physical security monitoring	Yes	AST-10	Protects corporate office co-working spaces and network closets from unauthorized physical intrusion.	Implemented	CCTV monitoring logs, badge access control logs, and visitor sign-in records at office locations.
Annex A.7.5	Physical	Protecting against physical and environmental threats	No	N/A (Excluded)	Excluded: NexusCloud SaaS is 100% cloud-hosted on AWS with zero on-premise data centers; physical environmental protection is inherited from AWS.	Not Applicable	AWS ISO 27001 Certification and SOC 2 Type II Report (Shared Responsibility Matrix).
Annex A.7.11	Physical	Supporting utilities	No	N/A (Excluded)	Excluded: NexusCloud does not operate physical server rooms or data center power/HVAC utilities; managed entirely by AWS.	Not Applicable	AWS Artifact compliance documentation for physical data center utility redundancy.
Annex A.8.2	Technological	Privileged access rights	Yes	AST-01 / AST-04	Restricts administrative access to AWS root accounts, Kubernetes clusters, and production databases.	Implemented	AWS IAM Identity Center temporary just-in-time (JIT) sessions, root key deactivation, and Python access audit script.
Annex A.8.5	Technological	Secure authentication	Yes	AST-03 / AST-04 / AST-05	Enforces strong cryptographic authentication across all cloud consoles, source code repos, and VPN/Zero-Trust gateways.	Implemented	Okta Adaptive MFA configuration logs, SSH key enforcement, and session timeout settings.
Annex A.8.8	Technological	Management of technical vulnerabilities	Yes	AST-01 / AST-05 / AST-07 / AST-14	Mitigates exploitation of unpatched container images, open-source dependencies, and web CMS plugins.	Implemented	Automated Software Composition Analysis (SCA), container vulnerability scanning in CI/CD, and regular DAST scans.
Annex A.8.9	Technological	Configuration management	Yes	AST-01	Prevents insecure configuration drift across Kubernetes clusters, cloud storage buckets, and Linux servers.	Implemented	Infrastructure-as-Code (Terraform) baselines and automated CIS benchmark compliance scans.
Annex A.8.11	Technological	Data masking	Yes	AST-13	Prevents support staff from viewing raw customer PII or sensitive tokens inside support tickets.	Implemented	Automated PII redaction and field-level masking configured in Zendesk and Jira ticketing workflows.
Annex A.8.12	Technological	Data leakage prevention	Yes	AST-02	Prevents unauthorized mass exfiltration of multi-tenant customer records from production databases.	Implemented	AWS GuardDuty exfiltration alerts, database query rate limits, and VPC endpoint boundary policies.
Annex A.8.13	Technological	Information backup	Yes	AST-08	Protects customer data against accidental loss or ransomware encryption/deletion.	Implemented	Automated daily AWS S3/RDS snapshots with S3 Object Lock (WORM immutability) and cross-region replication.

Control ID	Annex A Theme	Control Name	Applicable (Yes/No)	Linked Asset ID	Justification for Inclusion or Exclusion	Implementation Status	Control Implementation & Audit Evidence
Annex A.8.15	Technological	Logging	Yes	AST-12	Ensures tamper-proof audit trails exist across all cloud infrastructure, endpoints, and network layers for forensics.	Implemented	Centralized log ingestion into Wazuh SIEM and AWS CloudTrail with immutable write-once log buckets.
Annex A.8.16	Technological	Monitoring activities	Yes	AST-12	Detects anomalous behavior, brute-force attempts, and privilege escalation in real time.	Implemented	Wazuh SIEM custom detection rules, Zeek network traffic monitoring logs, and automated SOC alert playbooks.
Annex A.8.20	Technological	Network security	Yes	AST-01 / AST-10	Protects internal cloud workloads and office networks from lateral movement and man-in-the-middle attacks.	Implemented	AWS VPC private subnet isolation, Kubernetes network policies, and WPA3-Enterprise 802.1X Wi-Fi authentication.
Annex A.8.21	Technological	Security of network services	Yes	AST-10	Ensures corporate network infrastructure and guest Wi-Fi are strictly segregated from production systems.	Implemented	VLAN guest network segmentation, certificate-based device profiling, and firewall rule review logs.
Annex A.8.24	Technological	Use of cryptography	Yes	AST-02 / AST-08	Protects confidentiality and integrity of multi-tenant customer data and backups at rest and in transit.	Implemented	AES-256 encryption at rest via AWS KMS for PostgreSQL/S3 and mandatory TLS 1.3 for all data in transit.
Annex A.8.26	Technological	Application security requirements	Yes	AST-05 / AST-14	Protects customer-facing React web portal and marketing website from XSS, SQLi, and DDoS attacks.	Implemented	Cloudflare/AWS Web Application Firewall (WAF), Content Security Policy (CSP) headers, and input validation.
Annex A.8.28	Technological	Secure coding	Yes	AST-02 / AST-07 / AST-11	Prevents injection flaws, hardcoded secrets, and insecure API integrations in production code.	Implemented	Parameterized database queries, mandatory pre-commit git secrets scanning, and least-privilege OAuth scopes.
Annex A.8.30	Technological	Outsourced development	No	N/A (Excluded)	Excluded: All software engineering and development for NexusCloud SaaS is performed 100% in-house by full-time staff.	Not Applicable	Engineering organizational chart and SDLC policy confirming zero outsourced software development.
Annex A.8.31	Technological	Separation of development, test and production environments	Yes	AST-03 / AST-07	Prevents untested code or unauthorized developer actions from impacting live production environments.	Implemented	Dedicated AWS accounts for Dev, Staging, and Prod with GitHub Actions branch protection and PR approval gates.